

Secret Leakage Detection for Cloud CI/CD

Easy User Guide and Real-World Setup

Prepared by Tarun Swami | B24046 | IIT Mandi

b24046@students.iitmandi.ac.in

Your Repository
GitHub Action
Local scanner on runner
SARIF report
Code Scanning alerts

This guide explains exactly how to install, scan locally, use the dashboard, connect a friend repository, and read results.

1. What the project does

The scanner looks for hard-coded secrets in source code, Terraform, CloudFormation, CI/CD files, environment files, scripts, and documentation. It combines pattern matching, entropy, placeholders, file context, IaC resources, and CI/CD context.

The deterministic rules engine decides the final risk level. The optional Transformer provides supporting semantic evidence. A detected real credential should be rotated immediately; this tool does not rotate credentials automatically.

2. Friend repository: recommended setup

A friend does not need to copy the scanner source code. They add one workflow file to their own repository. First, push their project normally:

```
cd C:\path\to\friend-project
git add .
git commit -m "Initial project"
git push
```

Create this file

.github/workflows/secret-scan.yml

```
name: Secret scan

on:
  push:
  pull_request:
  workflow_dispatch:

permissions:
  contents: read
  security-events: write

jobs:
  scan:
    uses: swamitarun/Secret-Leakage-Detection-for-Cloud-CI-CD/.github/workflows/security-scan.yml@master
    secrets: inherit

git add .github/workflows/secret-scan.yml
git commit -m "Add secret leakage security scan"
git push
```

3. GitHub settings

- Open the friend repository on GitHub.
- Go to Settings, then Actions, then General.
- Under Workflow permissions, allow reading repository contents and writing security events.
- Do not enable contents write permission.
- Save the settings.

The permissions are needed even for a manual Run workflow: contents read lets the runner checkout the project, and security-events write lets GitHub accept the SARIF findings.

4. Run and read the scan

- Open the Actions tab.
- Select Secret scan.

- Press Run workflow.
- Select the branch, normally main.
- Press Run workflow again.

For automatic use, every push and pull request triggers the same scan. The workflow installs dependencies, runs tests, scans the repository, creates reports, and uploads SARIF.

Where results appear

- Actions, open the run, then Artifacts: download JSON, HTML, and SARIF.
- Security, then Code scanning alerts: view SARIF findings.
- Open a pull request: findings can appear inline when the alert maps to a changed file.

5. Understand pass and fail

A clean repository should finish with a green check. A HIGH or CRITICAL finding intentionally makes the job fail with exit code 1. This is a security gate, not a software crash.

Level	Meaning
SAFE	No actionable secret signal detected.
LOW / MEDIUM	Suspicious or contextual signal; review it.
HIGH / CRITICAL	CI gate fails. Remove or rotate the credential and investigate.

6. Local CLI use

Use the local CLI when you want a scan before pushing code. From the scanner repository:

```
cd C:\Study\404\my2\Secret-Leakage-Detection-for-Cloud-CI-CD
.\.venv\Scripts\Activate.ps1
python scanner\cli.py C:\path\to\friend-project --fail-on HIGH
```

To create all report formats:

```
python scanner\cli.py C:\path\to\friend-project \
--json reports\scan_report.json \
--html reports\scan_report.html \
--sarif reports\scan_report.sarif \
--fail-on HIGH
```

The command returns exit code 0 when the selected threshold is clear and exit code 1 when it finds a matching HIGH, CRITICAL, or MEDIUM violation.

7. Streamlit ZIP dashboard

The dashboard is the interactive file-upload interface. It runs locally on the user computer:

```
cd C:\Study\404\my2\Secret-Leakage-Detection-for-Cloud-CI-CD
.\.venv\Scripts\Activate.ps1
streamlit run dashboard\app.py
```

Open <http://localhost:8501>, choose ZIP upload, select a project archive, and press Run Security Scan. The UI shows findings and download buttons for JSON and HTML reports. ZIP protection rejects traversal and symlink entries and removes temporary extracted data.

8. What SARIF means

SARIF means Static Analysis Results Interchange Format. It is a standard JSON format that GitHub Code Scanning understands. SARIF is a report output, not a file-upload service and not a replacement for the scanner.

9. Safety checklist

- Never commit real credentials or raw secret data.
- Never paste complete secret values into an issue or chat.
- Rotate any real credential found by the scanner.
- Keep public GitHub Actions for code already allowed to run on GitHub-hosted runners.
- For a hosted ZIP service, add authentication, HTTPS, rate limits, temporary storage cleanup, and a privacy policy first.
- Treat Transformer scores as supporting evidence; use deterministic risk factors for the final gate.

10. Quick troubleshooting

Problem	Fix
Run workflow button missing	Confirm workflow file is under <code>.github/workflows</code> and includes <code>workflow_dispatch</code> .
Permission denied for SARIF	Set contents read and security-events write in the caller workflow and repository Actions settings.
SARIF file missing	Open scanner logs first. The workflow now skips SARIF upload when the scanner did not create it.
Job fails on HIGH/CRITICAL	This is the security gate. Review the file, remove the secret, rotate it, then push again.

Project repository: github.com/swamitarun/Secret-Leakage-Detection-for-Cloud-CI-CD | Author: Tarun Swami, IIT Mandi